CHECKPOINT 05 - DEVSECOPS

Pipeline DevSecOps Completo - Relatorio de Evidencias

Integrantes

Guilherme Santos - RM 551168

Enricco - RM 551717

Gabriel - RM 99227

Danilo - RM 99465

Laura - RM 98747

Objetivo

Bloquear segredos, codigo vulneravel e imagem Docker com CVE CRITICAL.

Jobs: Gitleaks (secret scanning), Semgrep (SAST) e Trivy (container scan).

Execucoes

Run #6 main SUCCESS - 3 jobs aprovados

Run #9 gitleaks-sabotage FAILURE - 2 leaks encontrados

Run #8 semgrep-sabotage FAILURE - 1 finding bloqueante

Run #11 trivy-sabotage FAILURE - 27 CVEs CRITICAL

Links completos estao no README e em docs/RELATORIO_EVIDENCIAS.md

Pipeline limpo - main - Run #6

Resultado: SUCCESS. As tres barreiras foram aprovadas.

```
Gitleaks - Secret Scanning ........ SUCCESS
Semgrep - SAST ..................... SUCCESS
Trivy - Container CVE Scan ........ SUCCESS

Target: cp05-devsecops (alpine 3.24.2)
Vulnerabilities: 0
Clean (no security findings detected)
```

Prova 1 - Gitleaks - Run #9

Segredo propositalmente falso detectado e pipeline bloqueado.

```
Finding: AWS_ACCESS_KEY_ID=REDACTED
RuleID: aws-access-token
File: security-tests/fake-secret.env
Line: 3

Finding: AWS_SECRET_ACCESS_KEY=REDACTED
RuleID: generic-api-key
File: security-tests/fake-secret.env
Line: 4

leaks found: 2
Leaks detected - FAILURE
```

Prova 2 - Semgrep - Run #8

Codigo vulneravel com eval() detectado e pipeline bloqueado.

```
1 Code Finding
security-tests/vulnerable_eval.py
python-dangerous-eval
Blocking
Uso de eval() detectado.
4 | result = eval(user_input)

Findings: 1 (1 blocking)
Process completed with exit code 1.
```

Prova adicional - Trivy - Run #11

Imagem antiga usada somente para provar o bloqueio de CVE CRITICAL.

```
Detected OS: family=debian version=9.8
OS version is no longer supported

Total: 27 (CRITICAL: 27)
dpkg | CVE-2022-1664 | CRITICAL | fixed
Installed: 1.18.25 | Fixed: 1.18.26

Process completed with exit code 1.
```

Conclusao

A main passa limpa e as sabotagens comprovam o bloqueio automatico dos tres gates.